AURELIUS DIGITAL SYSTEMS PVT. LTD.

INFORMATION SECURITY POLICY & PROCEDURES MANUAL

SEC-POL-01 | Version 7.1

Field	Controlled value
Document ID	SEC-POL-01
Version	7.1
Effective date	2026-08-01
Review date	2027-07-31
Classification	CONFIDENTIAL
Owner	Nikhil Varma (CISO)
Approver	Vikram Iyer (CTO)
Department	Information Security & Resilience
Applicability	All workers, systems, data, facilities, third parties, and approved client-delivery environments within scope
Status	APPROVED - CONTROLLED INTERNAL DOCUMENT

Fictional enterprise notice: Aurelius Digital Systems Pvt. Ltd., its identities, systems and internal rules in this document are fictional.

Document Control

SEC-POL-01-DC01 - Document-Control Record

Field	Controlled value
Document ID	SEC-POL-01
Title	Information Security Policy & Procedures Manual
Version	7.1
Status	Approved - Controlled Internal Document
Effective date	2026-08-01
Review date	2027-07-31
Owner	Nikhil Varma (CISO)
Approver	Vikram Iyer (CTO)
Department	Information Security & Resilience
Classification	CONFIDENTIAL
Applicability	All workers, systems, data, facilities, third parties, and approved client-delivery environments within scope
Controlled repository	VaultPoint DMS
Distribution	Authorized workforce and functions according to classification and applicability
External-law treatment	Where a decision depends on external law or a client obligation not contained here, obtain verified guidance from Legal & Corporate Affairs.

Revision History

SEC-POL-01-RH01 - Revision History

Version	Effective / status	Meaningful change
5.1	Prior controlled release	Initial controlled issue and consolidation of predecessor guidance.
5.6	Prior controlled release	Expanded scope, roles and source-of-truth controls.
6.1	Prior controlled release	Aligned enterprise systems, approval vocabulary and document interfaces.
6.5	Prior controlled release	Added clearer exception, recordkeeping and manager/accountability rules.
6.8	Prior controlled release	Refreshed operational workflows, conditional rules and cross-document handoffs.
7.1	2026-08-01	Current release aligned to enterprise governance baseline and approved process design.

Precedence: This document controls only within its approved subject. Specialist policies, standards and procedures control detailed requirements in their own subject matter; unresolved conflicts are escalated to the relevant Policy Owners.

Table of Contents

1 Security Policy Governance and Scope
- 1.1 Objectives and applicability
- 1.2 Security principles
- 1.3 Policy hierarchy and precedence
- 1.4 Client and third-party environments

2 Security Roles, Risk Ownership and Assurance
- 2.1 CISO and security teams
- 2.2 System, Data and Business Owners
- 2.3 Control Owners
- 2.4 Security risk assessment
- 2.5 Assurance and audit interface

3 Information Classification and Handling
- 3.1 Classification levels
- 3.2 Classification assignment
- 3.3 Need-to-know
- 3.4 External sharing
- 3.5 Printing and physical handling
- 3.6 Mixed-classification content

4 Asset Management
- 4.1 Asset inventory
- 4.2 Custodianship
- 4.3 Ownership
- 4.4 Asset lifecycle
- 4.5 Lost or unaccounted assets

5 Identity and Authentication Security Baseline
- 5.1 Unique identities
- 5.2 Credential protection
- 5.3 MFA baseline
- 5.4 Least privilege
- 5.5 Privileged access baseline
- 5.6 Detailed IAM standard handoff

6 Endpoint Security
- 6.1 Managed endpoint requirement
- 6.2 Endpoint protection
- 6.3 Hardening and configuration
- 6.4 Local administration
- 6.5 Device compliance
- 6.6 Lost/stolen endpoints

7 Network and Remote Access Security
- 7.1 Network segmentation
- 7.2 Secure remote access
- 7.3 VPN and approved connectivity
- 7.4 Wireless access
- 7.5 Client network access
- 7.6 Network exceptions

8 Cloud and SaaS Security
- 8.1 Approved cloud environments

Table of Contents - continued

8.2 Cloud account provisioning
8.3 SaaS approval boundary
8.4 Configuration baselines
8.5 Cloud logging
8.6 Shadow IT prohibition boundary

9 Email, Collaboration and Messaging Security

9.1 Corporate email use
9.2 External recipients
9.3 Sensitive attachments and links
9.4 Messaging and collaboration spaces
9.5 Malicious-message handling

10 Encryption, Keys and Secrets

10.1 Encryption expectations
10.2 Key management
10.3 Secret storage
10.4 Certificates
10.5 Restricted secret handling
10.6 Cryptographic exception governance

11 Backup, Restore and Data Recovery Controls

11.1 Backup ownership
11.2 Backup protection
11.3 Restore testing
11.4 Recovery dependency records
11.5 RTO/RPO handoff to continuity

12 Vulnerability, Patch and Configuration Management

12.1 Vulnerability identification
12.2 Risk prioritization
12.3 Patch governance
12.4 Configuration drift
12.5 Exception and compensating controls

13 Logging, Monitoring and Security Telemetry

13.1 Security logging
13.2 Monitoring coverage
13.3 Time synchronization
13.4 Log access and protection
13.5 Alert handling boundary

14 Secure Development and Application Security

14.1 Secure engineering expectations
14.2 Code and dependency review
14.3 Secrets in code
14.4 Security testing
14.5 Release security gates
14.6 Client delivery considerations

15 Phishing, Social Engineering and Human Security

15.1 Awareness
15.2 Reporting suspected phishing
15.3 Suspicious requests

Table of Contents - continued

15.4 Credential-reset social engineering
15.5 Targeted campaigns

16 Third-Party and Vendor Security

16.1 Security due diligence
16.2 Vendor connectivity
16.3 Shared responsibility
16.4 Critical vendor controls
16.5 Security obligations handoff to procurement

17 AI Tool and AI Workload Security

17.1 Approved AI access channels
17.2 Prompt/input sensitivity
17.3 Model/API credentials
17.4 AI agents and tool permissions
17.5 AI workload logging
17.6 AI governance handoff

18 Security Event and Incident Reporting

18.1 Security Event versus Security Incident
18.2 Worker reporting duty
18.3 SOC intake
18.4 Severity handoff
18.5 Privacy/vendor/AI incident concurrence

19 Business Continuity and Disaster Recovery Security Baseline

19.1 Security resilience principles
19.2 Continuity dependencies
19.3 Recovery access
19.4 Emergency changes
19.5 Detailed continuity manual handoff

20 Secure Disposal and Media Handling

20.1 Device retirement
20.2 Media sanitization
20.3 Paper disposal
20.4 Removable media
20.5 Third-party disposal

21 Security Exceptions and Risk Acceptance

21.1 Exception criteria
21.2 Compensating controls
21.3 Approval authorities
21.4 Validity and review
21.5 Revocation of exception

22 Compliance, Metrics and Continuous Improvement

22.1 Control evidence
22.2 Security metrics
22.3 Control testing
22.4 Remediation tracking
22.5 Policy review

Document Governance and Use

Establish the enterprise information-security control baseline and mandatory security procedures for information, technology assets, endpoints, networks, cloud services, vulnerabilities, monitoring, third parties, resilience, and secure use of AI services.

All workers, systems, data, facilities, third parties and approved client-delivery environments within scope; detailed IAM and incident execution are delegated to IAM-STD-03 and SEC-IR-004.

Audience: All workers; system/data owners; engineers; administrators; Security teams; Corporate Technology; business owners; vendor managers.

Controlled-source rule: Convenience copies, email extracts, screenshots and local notes do not supersede the controlled document or authoritative enterprise system for the relevant fact.

SEC-POL-01-DG01 - Document Dependencies

Dependency type	Documents
Primary	
Control	

1 Security Policy Governance and Scope

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 1 Security Policy Governance and Scope | Information Security & Resilience | CONFIDENTIAL

Security Policy Governance and Scope establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

1.1 Objectives and applicability

Objectives and applicability is governed as part of Security Policy Governance and Scope. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for objectives, applicability must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

1.2 Security principles

Security principles is governed as part of Security Policy Governance and Scope. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, principles must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

1.3 Policy hierarchy and precedence

Policy hierarchy and precedence is governed as part of Security Policy Governance and Scope. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for policy, hierarchy, precedence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

1.4 Client and third-party environments

Client and third-party environments is governed as part of Security Policy Governance and Scope. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for client, third, party, environments must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2 Security Roles, Risk Ownership and Assurance

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 2 Security Roles, Risk Ownership and Assurance | Information Security & Resilience | CONFIDENTIAL

Security Roles, Risk Ownership and Assurance establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

2.1 CISO and security teams

CISO and security teams is governed as part of Security Roles, Risk Ownership and Assurance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, teams must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T01 - Security Roles and Accountability Matrix

Role	Accountability	Evidence
Workers protect credentials,	Workers protect credentials, devices and information and report suspected security events promptly.	Workflow or controlled record
System and Data Owners class	System and Data Owners classify assets/data and fund required controls.	Workflow or controlled record
Security Governance & Risk i	Security Governance & Risk interprets security requirements and administers exceptions.	Workflow or controlled record

2.2 System, Data and Business Owners

System, Data and Business Owners is governed as part of Security Roles, Risk Ownership and Assurance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for system, business, owners must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.3 Control Owners

Control Owners is governed as part of Security Roles, Risk Ownership and Assurance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for control, owners must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S01: Employee tries to send CONFIDENTIAL client data to a personal email address. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

2.4 Security risk assessment

Security risk assessment is governed as part of Security Roles, Risk Ownership and Assurance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, assessment must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

2.5 Assurance and audit interface

Assurance and audit interface is governed as part of Security Roles, Risk Ownership and Assurance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for assurance, audit, interface must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3 Information Classification and Handling

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 3 Information Classification and Handling | Information Security & Resilience | CONFIDENTIAL

Information Classification and Handling establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

3.1 Classification levels

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for classification, levels must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T02 - Information Handling by Classification

Code	Class	Definition	Minimum handling
ADS-PUB	PUBLIC	Information approved for unrestricted external distribution by an authorized owner or publication process.	Integrity and authorized-publication controls; no assumption that all externally visible drafts are Public.
ADS-INT	INTERNAL	Default company information intended for Aurelius workforce use and not approved for public release.	Use company-approved systems; share externally only for legitimate business need and with appropriate authorization.
ADS-CONF	CONFIDENTIAL	Information whose unauthorized disclosure, alteration, or loss could materially harm Aurelius, a client, worker, or business relationship.	Need-to-know access; approved managed systems; encryption in transit and at rest where supported; controlled external sharing; enhanced logging where applicable.
ADS-REST	RESTRICTED	Highest internal protection level for information requiring tightly limited access because compromise could cause severe harm or enable material misuse.	Explicit authorized users; strongest available access controls; managed storage only; no public AI submission; no unmanaged removable media; specialist approval for external transfer.

3.2 Classification assignment

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for classification, assignment must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Data Privacy & Data Governance Policy (PRIV-DG-02) §3 - Personal-data/classification overlay. This reference supplements this section and does not transfer ownership of unrelated rules.

3.3 Need-to-know

Need-to-know is governed as part of Information Classification and Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for this activity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.4 External sharing

External sharing is governed as part of Information Classification and Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for external, sharing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3.5 Printing and physical handling

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for printing, physical, handling must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S02: Developer discovers an API secret committed to CodeForge Enterprise. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

3.6 Mixed-classification content

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for mixed, classification, content must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

3 Information Classification and Handling - continued

4 Asset Management

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 4 Asset Management | Information Security & Resilience | CONFIDENTIAL

Asset Management establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

4.1 Asset inventory

Asset inventory is governed as part of Asset Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for asset, inventory must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4.2 Custodianship

Custodianship is governed as part of Asset Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for custodianship must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T03 - Asset Ownership and Custody Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

4.3 Ownership

Ownership is governed as part of Asset Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for ownership must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4.4 Asset lifecycle

Asset lifecycle is governed as part of Asset Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for asset, lifecycle must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

4.5 Lost or unaccounted assets

Lost or unaccounted assets is governed as part of Asset Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for unaccounted, assets must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5 Identity and Authentication Security Baseline

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 5 Identity and Authentication Security Baseline | Information Security & Resilience | CONFIDENTIAL

Identity and Authentication Security Baseline establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

5.1 Unique identities

Unique identities is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for unique, identities must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.2 Credential protection

Credential protection is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for credential, protection must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T04 - Security Control Baseline by Technology Domain

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record
Operational scenario S03: Managed endpoint falls out of DeviceCentral compliance while user is remote. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.		

5.3 MFA baseline

MFA baseline is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for baseline must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.4 Least privilege

Least privilege is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for least, privilege must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.5 Privileged access baseline

Privileged access baseline is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for privileged, access, baseline must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

5.6 Detailed IAM standard handoff

Detailed IAM standard handoff is governed as part of Identity and Authentication Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for detailed, standard, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Identity, Access Management & Acceptable Technology Use Standard (IAM-STD-03) §5 - Detailed authentication and MFA. This reference supplements this section and does not transfer ownership of unrelated rules.

6 Endpoint Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 6 Endpoint Security | Information Security & Resilience | CONFIDENTIAL

Endpoint Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

6.1 Managed endpoint requirement

Managed endpoint requirement is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for managed, endpoint, requirement must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.2 Endpoint protection

Endpoint protection is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for endpoint, protection must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T05 - Endpoint Compliance Decision Table

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

6.3 Hardening and configuration

Hardening and configuration is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for hardening, configuration must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.4 Local administration

Local administration is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for local, administration must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S04: Team proposes an unapproved SaaS collaboration tool. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

6.5 Device compliance

Device compliance is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for device, compliance must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

6.6 Lost/stolen endpoints

Lost/stolen endpoints is governed as part of Endpoint Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for stolen, endpoints must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7 Network and Remote Access Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 7 Network and Remote Access Security | Information Security & Resilience | CONFIDENTIAL

Network and Remote Access Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

7.1 Network segmentation

Network segmentation is governed as part of Network and Remote Access Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for network, segmentation must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.2 Secure remote access

Secure remote access is governed as part of Network and Remote Access Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for secure, remote, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.3 VPN and approved connectivity

VPN and approved connectivity is governed as part of Network and Remote Access Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for approved, connectivity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.4 Wireless access

Wireless access is governed as part of Network and Remote Access Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for wireless, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.5 Client network access

Client network access is governed as part of Network and Remote Access Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for client, network, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

7.6 Network exceptions

Security exceptions are time-bound and normally may not exceed 90 days without Security & Resilience Steering Committee review. The request must identify the unmet control, affected assets/data, business need, threat exposure, compensating controls, owner and expiry action.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for network, exceptions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S05: Privileged administrator asks to store a production password in chat. Do not share credentials. Use AccessHub/KeyFort emergency or delegated-access procedures and report suspected compromise. Operational urgency changes the escalation path, not the requirement for individual accountability.

8 Cloud and SaaS Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 8 Cloud and SaaS Security | Information Security & Resilience | CONFIDENTIAL

Cloud and SaaS Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

8.1 Approved cloud environments

Approved cloud environments is governed as part of Cloud and SaaS Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for approved, cloud, environments must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.2 Cloud account provisioning

Cloud account provisioning is governed as part of Cloud and SaaS Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for cloud, account, provisioning must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T06 - Cloud/SaaS Security Review Triggers

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

8.3 SaaS approval boundary

SaaS approval boundary is governed as part of Cloud and SaaS Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for approval, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.4 Configuration baselines

Configuration baselines is governed as part of Cloud and SaaS Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for configuration, baselines must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.5 Cloud logging

Systems handling CONFIDENTIAL or RESTRICTED information must generate security-relevant logs sufficient to identify authentication, privileged action, material configuration change and security-control events. Central security telemetry is retained for at least 180 days unless a longer period is required by an approved service or client record.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for cloud, logging must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

8.6 Shadow IT prohibition boundary

Shadow IT prohibition boundary is governed as part of Cloud and SaaS Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for shadow, prohibition, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9 Email, Collaboration and Messaging Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 9 Email, Collaboration and Messaging Security | Information Security & Resilience | CONFIDENTIAL

Email, Collaboration and Messaging Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

9.1 Corporate email use

Corporate email use is governed as part of Email, Collaboration and Messaging Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for corporate, email must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.2 External recipients

External recipients is governed as part of Email, Collaboration and Messaging Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for external, recipients must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.3 Sensitive attachments and links

Sensitive attachments and links is governed as part of Email, Collaboration and Messaging Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for sensitive, attachments, links must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S06: Business owner wants a temporary exception to a critical patch deadline. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

9.4 Messaging and collaboration spaces

Messaging and collaboration spaces is governed as part of Email, Collaboration and Messaging Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for messaging, collaboration, spaces must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

9.5 Malicious-message handling

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for malicious, message, handling must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10 Encryption, Keys and Secrets

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 10 Encryption, Keys and Secrets | Information Security & Resilience | CONFIDENTIAL

Encryption, Keys and Secrets establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

10.1 Encryption expectations

CONFIDENTIAL and RESTRICTED information must use approved encryption in transit and at rest where supported by the managed platform. Private keys, production administrative credentials and comparable secrets must be held in managed key or secret services; copying them into email, collaboration chat, source code or unmanaged documents is prohibited.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for encryption, expectations must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.2 Key management

Key management is governed as part of Encryption, Keys and Secrets. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for management must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T07 - Encryption and Secret Handling Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

10.3 Secret storage

Secret storage is governed as part of Encryption, Keys and Secrets. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for secret, storage must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.4 Certificates

Certificates is governed as part of Encryption, Keys and Secrets. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for certificates must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.5 Restricted secret handling

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for restricted, secret, handling must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

10.6 Cryptographic exception governance

Security exceptions are time-bound and normally may not exceed 90 days without Security & Resilience Steering Committee review. The request must identify the unmet control, affected assets/data, business need, threat exposure, compensating controls, owner and expiry action.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for cryptographic, exception, governance must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S07: Vendor requests direct network access to a support environment. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

11 Backup, Restore and Data Recovery Controls

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 11 Backup, Restore and Data Recovery Controls | Information Security & Resilience | CONFIDENTIAL

Backup, Restore and Data Recovery Controls establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

11.1 Backup ownership

Backup ownership is governed as part of Backup, Restore and Data Recovery Controls. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for backup, ownership must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.2 Backup protection

Backup protection is governed as part of Backup, Restore and Data Recovery Controls. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for backup, protection must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.3 Restore testing

Restore testing is governed as part of Backup, Restore and Data Recovery Controls. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for restore, testing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.4 Recovery dependency records

Recovery dependency records is governed as part of Backup, Restore and Data Recovery Controls. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for recovery, dependency, records must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

11.5 RTO/RPO handoff to continuity

RTO/RPO handoff to continuity is governed as part of Backup, Restore and Data Recovery Controls. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for handoff, continuity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12 Vulnerability, Patch and Configuration Management

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 12 Vulnerability, Patch and Configuration Management | Information Security & Resilience | CONFIDENTIAL

Vulnerability, Patch and Configuration Management establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

12.1 Vulnerability identification

Security remediation targets are based on risk and exploitability. Critical vulnerabilities in internet-facing or privileged systems are remediated within 7 calendar days; High within 14 days; Medium within 30 days; Low within 90 days, unless Security approves a documented compensating control and due date.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for vulnerability, identification must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T08 - Vulnerability/Patch Prioritization Matrix

Risk	Internal remediation target	Escalation
Critical	7 calendar days	Security exception if unmet
High	14 calendar days	Control Owner + Security review
Medium	30 calendar days	Tracked remediation
Low	90 calendar days	Risk-based backlog

12.2 Risk prioritization

Risk prioritization is governed as part of Vulnerability, Patch and Configuration Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for prioritization must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S08: Public LLM prompt would contain client data. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

12.3 Patch governance

Security remediation targets are based on risk and exploitability. Critical vulnerabilities in internet-facing or privileged systems are remediated within 7 calendar days; High within 14 days; Medium within 30 days; Low within 90 days, unless Security approves a documented compensating control and due date.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for patch, governance must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.4 Configuration drift

Configuration drift is governed as part of Vulnerability, Patch and Configuration Management. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for configuration, drift must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

12.5 Exception and compensating controls

Security exceptions are time-bound and normally may not exceed 90 days without Security & Resilience Steering Committee review. The request must identify the unmet control, affected assets/data, business need, threat exposure, compensating controls, owner and expiry action.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for exception, compensating, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13 Logging, Monitoring and Security Telemetry

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 13 Logging, Monitoring and Security Telemetry | Information Security & Resilience | CONFIDENTIAL

Logging, Monitoring and Security Telemetry establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

13.1 Security logging

Systems handling CONFIDENTIAL or RESTRICTED information must generate security-relevant logs sufficient to identify authentication, privileged action, material configuration change and security-control events. Central security telemetry is retained for at least 180 days unless a longer period is required by an approved service or client record.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, logging must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T09 - Security Logging Minimums

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

13.2 Monitoring coverage

Monitoring coverage is governed as part of Logging, Monitoring and Security Telemetry. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for monitoring, coverage must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.3 Time synchronization

Time synchronization is governed as part of Logging, Monitoring and Security Telemetry. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for synchronization must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

13.4 Log access and protection

Log access and protection is governed as part of Logging, Monitoring and Security Telemetry. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for access, protection must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S09: DataGuard blocks transfer to removable media during client delivery. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

13.5 Alert handling boundary

Aurelius uses exactly four information classifications: PUBLIC, INTERNAL, CONFIDENTIAL and RESTRICTED. Client information is at least CONFIDENTIAL unless expressly approved for public release; credentials, private keys and equivalent privileged secrets are RESTRICTED. The highest applicable classification controls a combined dataset unless effective segregation is maintained.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for alert, handling, boundary must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14 Secure Development and Application Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 14 Secure Development and Application Security | Information Security & Resilience | CONFIDENTIAL

Secure Development and Application Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

14.1 Secure engineering expectations

Secure engineering expectations is governed as part of Secure Development and Application Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for secure, engineering, expectations must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.2 Code and dependency review

Code and dependency review is governed as part of Secure Development and Application Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for dependency, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.3 Secrets in code

CONFIDENTIAL and RESTRICTED information must use approved encryption in transit and at rest where supported by the managed platform. Private keys, production administrative credentials and comparable secrets must be held in managed key or secret services; copying them into email, collaboration chat, source code or unmanaged documents is prohibited.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for secrets must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.4 Security testing

Security testing is governed as part of Secure Development and Application Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, testing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.5 Release security gates

Release security gates is governed as part of Secure Development and Application Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for release, security, gates must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

14.6 Client delivery considerations

Client delivery considerations is governed as part of Secure Development and Application Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for client, delivery, considerations must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S10: Security monitoring identifies suspicious cloud API activity. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

15 Phishing, Social Engineering and Human Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 15 Phishing, Social Engineering and Human Security | Information Security & Resilience | CONFIDENTIAL

Phishing, Social Engineering and Human Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

15.1 Awareness

Awareness is governed as part of Phishing, Social Engineering and Human Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for awareness must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.2 Reporting suspected phishing

Reporting suspected phishing is governed as part of Phishing, Social Engineering and Human Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for reporting, suspected, phishing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.3 Suspicious requests

Suspicious requests is governed as part of Phishing, Social Engineering and Human Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for suspicious, requests must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.4 Credential-reset social engineering

Credential-reset social engineering is governed as part of Phishing, Social Engineering and Human Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for credential, reset, social, engineering must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

15.5 Targeted campaigns

Targeted campaigns is governed as part of Phishing, Social Engineering and Human Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for targeted, campaigns must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16 Third-Party and Vendor Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 16 Third-Party and Vendor Security | Information Security & Resilience | CONFIDENTIAL

Third-Party and Vendor Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

16.1 Security due diligence

Security due diligence is governed as part of Third-Party and Vendor Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, diligence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T10 - Third-Party Security Control Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

16.2 Vendor connectivity

Vendor connectivity is governed as part of Third-Party and Vendor Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for vendor, connectivity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16.3 Shared responsibility

Shared responsibility is governed as part of Third-Party and Vendor Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for shared, responsibility must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S11: Laptop is lost during corporate travel. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

16.4 Critical vendor controls

Critical vendor controls is governed as part of Third-Party and Vendor Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for critical, vendor, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

16.5 Security obligations handoff to procurement

Security obligations handoff to procurement is governed as part of Third-Party and Vendor Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, obligations, handoff, procurement must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Procurement, Vendor & Third-Party Risk Management Policy (PROC-TPRM-11) §9 - Vendor security/privacy assessment. This reference supplements this section and does not transfer ownership of unrelated rules.

17 AI Tool and AI Workload Security

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 17 AI Tool and AI Workload Security | Information Security & Resilience | CONFIDENTIAL

AI Tool and AI Workload Security establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

17.1 Approved AI access channels

Approved AI access channels is governed as part of AI Tool and AI Workload Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for approved, access, channels must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T11 - AI Security Handling Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

17.2 Prompt/input sensitivity

Prompt/input sensitivity is governed as part of AI Tool and AI Workload Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for prompt, input, sensitivity must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.3 Model/API credentials

Model/API credentials is governed as part of AI Tool and AI Workload Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for model, credentials must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.4 AI agents and tool permissions

AI agents and tool permissions is governed as part of AI Tool and AI Workload Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for agents, permissions must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

17.5 AI workload logging

Systems handling CONFIDENTIAL or RESTRICTED information must generate security-relevant logs sufficient to identify authentication, privileged action, material configuration change and security-control events. Central security telemetry is retained for at least 180 days unless a longer period is required by an approved service or client record.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for workload, logging must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S12: A recovery procedure requires emergency administrative access during a major incident. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

17.6 AI governance handoff

AI governance handoff is governed as part of AI Tool and AI Workload Security. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for governance, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: AI, Machine Learning & Generative AI Governance Standard (AI-GOV-05) §3 - AI governance risk tiers. This reference supplements this section and does not transfer ownership of unrelated rules.

18 Security Event and Incident Reporting

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 18 Security Event and Incident Reporting | Information Security & Resilience | CONFIDENTIAL

Security Event and Incident Reporting establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

18.1 Security Event versus Security Incident

Security Event versus Security Incident is governed as part of Security Event and Incident Reporting. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, event, versus, security must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.2 Worker reporting duty

Worker reporting duty is governed as part of Security Event and Incident Reporting. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for worker, reporting must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.3 SOC intake

SOC intake is governed as part of Security Event and Incident Reporting. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for intake must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

18.4 Severity handoff

Severity handoff is governed as part of Security Event and Incident Reporting. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for severity, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Security Incident Response & Business Continuity Manual (SEC-IR-004) §3 - Severity classification and response. This reference supplements this section and does not transfer ownership of unrelated rules.

18.5 Privacy/vendor/AI incident concurrence

Privacy/vendor/AI incident concurrence is governed as part of Security Event and Incident Reporting. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for privacy, vendor, incident, concurrence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19 Business Continuity and Disaster Recovery Security Baseline

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 19 Business Continuity and Disaster Recovery Security Baseline | Information Security & Resilience | CONFIDENTIAL

Business Continuity and Disaster Recovery Security Baseline establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

19.1 Security resilience principles

Security resilience principles is governed as part of Business Continuity and Disaster Recovery Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, resilience, principles must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.2 Continuity dependencies

Continuity dependencies is governed as part of Business Continuity and Disaster Recovery Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for continuity, dependencies must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.3 Recovery access

Recovery access is governed as part of Business Continuity and Disaster Recovery Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for recovery, access must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Operational scenario S13: Engineer wants to disable endpoint protection for performance testing. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

19.4 Emergency changes

Emergency changes is governed as part of Business Continuity and Disaster Recovery Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for emergency, changes must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

19.5 Detailed continuity manual handoff

Detailed continuity manual handoff is governed as part of Business Continuity and Disaster Recovery Security Baseline. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for detailed, continuity, manual, handoff must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Related controlled source: Security Incident Response & Business Continuity Manual (SEC-IR-004) §21 - Business continuity governance. This reference supplements this section and does not transfer ownership of unrelated rules.

20 Secure Disposal and Media Handling

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 20 Secure Disposal and Media Handling | Information Security & Resilience | CONFIDENTIAL

Secure Disposal and Media Handling establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

20.1 Device retirement

Device retirement is governed as part of Secure Disposal and Media Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for device, retirement must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.2 Media sanitization

Media sanitization is governed as part of Secure Disposal and Media Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for media, sanitization must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.3 Paper disposal

Paper disposal is governed as part of Secure Disposal and Media Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for paper, disposal must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.4 Removable media

Removable media is governed as part of Secure Disposal and Media Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for removable, media must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

20.5 Third-party disposal

Third-party disposal is governed as part of Secure Disposal and Media Handling. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for third, party, disposal must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21 Security Exceptions and Risk Acceptance

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 21 Security Exceptions and Risk Acceptance | Information Security & Resilience | CONFIDENTIAL

Security Exceptions and Risk Acceptance establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

21.1 Exception criteria

Security exceptions are time-bound and normally may not exceed 90 days without Security & Resilience Steering Committee review. The request must identify the unmet control, affected assets/data, business need, threat exposure, compensating controls, owner and expiry action.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for exception, criteria must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.2 Compensating controls

Compensating controls is governed as part of Security Exceptions and Risk Acceptance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for compensating, controls must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

SEC-POL-01-T12 - Security Exception Approval Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

Operational scenario S14: A client requires stricter handling than Aurelius baseline. Apply the requirements in Information Security Policy & Procedures Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

21.3 Approval authorities

Approval authorities is governed as part of Security Exceptions and Risk Acceptance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for approval, authorities must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.4 Validity and review

Validity and review is governed as part of Security Exceptions and Risk Acceptance. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for validity, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

21.5 Revocation of exception

Security exceptions are time-bound and normally may not exceed 90 days without Security & Resilience Steering Committee review. The request must identify the unmet control, affected assets/data, business need, threat exposure, compensating controls, owner and expiry action.

The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for revocation, exception must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22 Compliance, Metrics and Continuous Improvement

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section 22 Compliance, Metrics and Continuous Improvement | Information Security & Resilience | CONFIDENTIAL

Compliance, Metrics and Continuous Improvement establishes the requirements, responsibilities and decision rules that apply within this part of Information Security Policy & Procedures Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

22.1 Control evidence

Control evidence is governed as part of Compliance, Metrics and Continuous Improvement. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for control, evidence must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.2 Security metrics

Security metrics is governed as part of Compliance, Metrics and Continuous Improvement. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for security, metrics must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.3 Control testing

Control testing is governed as part of Compliance, Metrics and Continuous Improvement. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for control, testing must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.4 Remediation tracking

Remediation tracking is governed as part of Compliance, Metrics and Continuous Improvement. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for remediation, tracking must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

22.5 Policy review

Policy review is governed as part of Compliance, Metrics and Continuous Improvement. The control is mandatory for systems, workers and information within scope unless an approved security exception explicitly applies.

Implementation for policy, review must be technically enforceable where feasible, monitored for material failure and documented by the accountable Control Owner. Control Owners must implement the requirement in managed technology, keep evidence of operation and escalate gaps through Security Governance & Risk.

- Workers protect credentials, devices and information and report suspected security events promptly.
- System and Data Owners classify assets/data and fund required controls.
- Do not use convenience, delivery pressure or a legacy practice as an undocumented exception.
- Where a control cannot be met, use the formal exception and compensating-control process before normal operation continues.

Appendices, Forms and Checklists

Information Security Policy & Procedures Manual | SEC-POL-01 | v7.1 | Effective 2026-08-01 | Section Appendices Controlled execution aids | Information Security & Resilience | CONFIDENTIAL

SEC-POL-01-AA Security Definitions and Control Vocabulary

Term	Controlled meaning
Credential	Authentication information used to prove identity or authorize access, including passwords, tokens, certificates, private keys, recovery codes, and equivalent secrets.
Security Incident	Security event or series of events that compromises, or credibly threatens to compromise, confidentiality, integrity, availability, authentication, or control of company/client resources.
Privacy Incident	Event involving unauthorized or inappropriate collection, access, use, disclosure, alteration, loss, retention, or deletion of Personal Data; may also be a Security Incident.
Major Incident	SEV-1 incident, or a designated SEV-2 incident, requiring coordinated cross-functional incident management.
Corporate Device	Endpoint owned or company-managed by Aurelius and enrolled in required management/security controls.
BYOD	Personally owned device permitted for limited company access under IAM-STD-03 and device-management conditions.
Record	Information retained as evidence of a business decision, transaction, approval, obligation, incident, or controlled activity.
Source of Truth	Designated authoritative system or controlled document for a particular fact or process. Convenience copies do not override it.

SEC-POL-01-AB Information Handling Quick Reference

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

SEC-POL-01-AC Security Exception Evidence Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Information Security Policy & Procedures Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-POL-01-AD Security Contact and Escalation Matrix

Contact	Purpose
security@aureliusdigital.example	Security governance questions, control guidance, and non-urgent security concerns
soc@aureliusdigital.example	Security incident and suspected compromise reporting; monitored 24x7
phishing@aureliusdigital.example	Suspected phishing and malicious-message reporting
bcm@aureliusdigital.example	Business continuity planning and exercise coordination

SEC-POL-01-AE Secure Disposal Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Information Security Policy & Procedures Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-POL-01-F01 Security Exception Request

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

SEC-POL-01-F02 Security Risk Acceptance Record

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	